FACULTAD DE INGENIERÍA DE PRODUCCIÓN Y SERVICIOS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS

Auditoría de Sistemas (1704255)

AGENTE DE CONTROLES Y SOA PARA PIMS ISO/IEC 27701:2025

TIF – Primera Parte: De Prompt a Skill en Sistemas Multi-Agente

AUTORES:
Ajra Huasco Jeans Anthony
Gutierrez Ccama Juan Diego
Suclle Suca Michael Benjamin
Garambel Marín Fernando Miguel
Hanco Mullisaca Sergio Danilo

DOCENTE:
Mg. Edward Vicente Zárate Carlos

CURSO:
Auditoría de Sistemas (1704255)

LUGAR:
Arequipa, Perú

FECHA:
02 de Octubre de 2026

Índice

1 Introducción y Marco General . . . 1
1.1 Introducción . . . 1
1.2 Objetivos del Proyecto . . . 1
1.2.1 Objetivo General . . . 1
1.2.2 Objetivos Específicos . . . 1
1.3 Contexto Normativo: Estructura Armonizada e ISO/IEC 27701:2025 . . . 2
1.3.1 Estructura de Alto Nivel (Cláusulas 1 a 10) . . . 2
1.3.2 Roles Organizacionales y Estructura del Anexo A . . . 3
1.3.3 El Rol del DPO y la Gobernanza . . . 3
1.4 El Ecosistema Multi-Agente: Arquitectura en Dos Pisos . . . 3
2 Desarrollo Metodológico e Implementación . . . 4
2.1 De Prompt a Skill: Transformación y Metodología . . . 4
2.1.1 Transformación del Caso 1: Elaboración de la Declaración de Aplicabilidad (SoA) y Mapeo de Políticas . . . 4
2.1.2 Transformación del Caso 2: Auditoría y Verificación de un Control Específico . . . 5
2.2 Especificación Formal de los Skills . . . 5
2.2.1 Ficha Técnica del Skill `generar-soa` . . . 5
2.2.2 Ficha Técnica del Skill `verificar-controles` . . . 7
2.3 Definición y Modelado del Asistente . . . 7
2.4 Arquitectura del Sistema, Papel del Agente de Riesgos y Contratos de Integración . . . 8
2.4.1 El Papel del Agente de Riesgos en la Arquitectura Multi-Agente . . . 9
2.4.2 Contrato Estándar de Comunicación Inter-Agentes . . . 9
2.4.3 Flujo de Ejecución e Interacción Temporal . . . 10
2.5 Tecnologías, Motor Determinista e Infraestructura . . . 10
2.6 Demostración y Plan de Pruebas . . . 12
2.6.1 Análisis y Verificación de los Resultados del Plan de Pruebas . . . 12
3 Conclusiones y Trabajo Futuro . . . 13
3.1 Conclusiones . . . 13
3.2 Limitaciones . . . 13
3.3 Hoja de Ruta y Recomendaciones para la Entrega 2 . . . 13
Referencias Bibliográficas . . . 14
4 Anexos . . . 14
4.1 Anexo A: Catálogo de Controles de Privacidad (`catalogo_controles.json`) . . . 14
4.2 Anexo B: Especificación de Archivos `SKILL.md` . . . 15
4.2.1 Skill `generar-soa` (`skills/generar-soa/SKILL.md`) . . . 15
4.2.2 Skill `verificar-controles` (`skills/verificar-controles/SKILL.md`) . . . 16
4.3 Anexo C: Código Fuente Base . . . 17
4.3.1 Módulo RAG Local (`rag.py`) . . . 17
4.3.2 Agente de Controles (`agents/controles.py`) . . . 18

1 Introducción y Marco General

1.1 Introducción

El aseguramiento de la privacidad y la protección de los Datos de Identificación Personal (PII, *Personally Identifiable Information*) se han consolidado como pilares regulatorios, operacionales y éticos en la era digital. En este contexto, la norma internacional **ISO/IEC 27701:2025** [1] establece los requisitos y directrices para implementar, mantener y auditar un Sistema de Gestión de Información de Privacidad (PIMS, *Privacy Information Management System*). Concebida en su edición 2025 como una norma de gestión independiente y autónoma pero armonizada con las normas ISO/IEC 27001:2022 [2] e ISO/IEC 27002, se alinea además con marcos regulatorios globales como el Reglamento General de Protección de Datos (GDPR) [3] y los estándares de gobernanza de inteligencia artificial como ISO/IEC 42001:2023 [4].

Dentro del ciclo de vida de un PIMS, la **Declaración de Aplicabilidad (SoA, *Statement of Applicability*)** representa el instrumento técnico y legal más crítico. En ella se documenta formalmente qué controles normativos aplican a la organización, cuáles se excluyen, la justificación preceptiva de cada decisión y el estado real y verificable de su implementación. No obstante, la gestión tradicional de la SoA suele sufrir de dispersión probatoria, inconsistencias humanas y una alta carga burocrática.

Para superar estas limitaciones, este proyecto aborda la transición paradigmática **De Prompt a Skill** en el marco de una arquitectura de **Sistemas Multi-Agente (MAS, *Multi-Agent Systems*)**. Mientras que un prompt convencional es una instrucción no estructurada, reactiva y propensa a alucinaciones, un **Skill** es una unidad de procedimiento determinista, modular, reusable y gobernada por contratos de datos tipados. En este informe se detalla el diseño y construcción del **Agente de Controles**, el componente articulador que sintetiza la información de todo el sistema para emitir la SoA y auditar el cumplimiento normativo.

1.2 Objetivos del Proyecto

1.2.1 Objetivo General

Diseñar, implementar y validar experimentalmente el **Agente de Controles** para un PIMS bajo la norma ISO/IEC 27701:2025, transformando tareas de auditoría en **Skills especializados deterministas** e interoperables mediante contratos JSON estándar en una arquitectura multi-agente.

1.2.2 Objetivos Específicos

- **Formalizar la metodología «De Prompt a Skill»:** Transformar consultas abiertas y ad-hoc en procedimientos reproducibles y tipados (`generar-soa` y `verificar-controles`).
- **Garantizar la auditabilidad y mitigación de alucinaciones:** Implementar un motor de reglas determinista que impida declarar controles implementados sin evidencias objetivas y verificables.

- **Integrar conocimiento semántico local (RAG):** Implementar un índice vectorial con embeddings multilingües y FAISS para vincular políticas internas y cláusulas de la norma sin dependencia de servicios externos.
- **Establecer el protocolo de interoperabilidad inter-agentes:** Diseñar el contrato estándar JSON para la comunicación horizontal con los otros 7 agentes del PIMS y la integración vertical con el orquestador.
- **Establecer las bases para la Entrega 2:** Diseñar una arquitectura modular capaz de evolucionar hacia la orquestación distribuida, contenedores Docker y validación con datos sintéticos y entornos reales.

1.3 Contexto Normativo: Estructura Armonizada e ISO/IEC 27701:2025

1.3.1 Estructura de Alto Nivel (Cláusulas 1 a 10)

Al igual que los estándares modernos de gestión (como ISO/IEC 27001 e ISO/IEC 42001), la norma ISO/IEC 27701:2025 adopta la Estructura Armonizada (*Harmonized Structure* / HLS), compuesta por 10 cláusulas fundamentales:

CláusulaDenominación y AlcanceRelevancia en el PIMS / Agente

1. Alcance

Delimitación del PIMS y tipos de organizaciones cubiertasDefine si la entidad es responsable o encargada

2. Normas de referencia

Vínculo mandatorio con ISO/IEC 27001 e ISO/IEC 27002Marco de seguridad base

3. Términos y definiciones

Conceptos clave: PII, titular de datos, DPO, brechaVocabulario formal del sistema

4. Contexto

Comprensión de la organización, partes interesadas y PIIEntrada del Agente de Inventario

5. Liderazgo

Compromiso de la alta dirección y política de privacidadMarco de gobernanza institucional

6. Planificación

6.1.2 Evaluación de riesgos; 6.1.3 Tratamiento de riesgos / SoA**Núcleo del Agente de Controles y Riesgos**

7. Soporte

Recursos, competencia (7.2), concienciación (7.3) e info. doc. (7.5)Agente de Formación y Repositorio

8. Operación

Planificación y control operacional; evaluaciones DPIAAgente de Riesgos y Terceros

9. Evaluación de desempeño

9.1 Seguimiento y medición; 9.2 Auditoría interna; 9.3 Revisión**Base probatoria del Agente de Evidencia**

10. Mejora

No conformidades, acciones correctivas y mejora continuaAgente de Incidentes y Planes de acción

1.3.2 Roles Organizacionales y Estructura del Anexo A

La norma ISO/IEC 27701:2025 exige diferenciar explícitamente el rol que asume la organización:

1. **Responsable del Tratamiento (*PII Controller*):** Determina las finalidades y medios del tratamiento de datos personales. Está sujeto a los **Controles A.1** (gobierno, finalidades, derechos de titulares y DPIA).
2. **Encargado del Tratamiento (*PII Processor*):** Trata datos exclusivamente bajo instrucciones del responsable. Está sujeto a los **Controles A.2** (gestión de subencargados, asistencia técnica y transferencias).
3. **Controles Comunes (A.3):** Controles transversales de seguridad operacional, respuesta a incidentes y concienciación, obligatorios para **ambos roles**.

1.3.3 El Rol del DPO y la Gobernanza

El estándar contempla la figura del **Oficial de Protección de Datos (DPO, *Data Protection Officer*)** como garante del cumplimiento normativo. En nuestra arquitectura, el sistema automatizado actúa como un asistente analítico avanzado; por tanto, la SoA emitida ostenta carácter de **propuesta técnica auditada**, requiriendo preceptivamente la bandera de supervisión y aprobación humana (`requiere_revision_humana = true`).

1.4 El Ecosistema Multi-Agente: Arquitectura en Dos Pisos

Para abordar la complejidad de un PIMS corporativo, la solución se concibe en dos niveles arquitectónicos:

- **Primer Piso (Capa Tradicional / Transaccional):** Modelado de datos, tablas maestras de sistemas, repositorios de políticas, registros de actividades de tratamiento (RAT) y almacenamiento de evidencias (similar a las plataformas tradicionales de cumplimiento y GDPR).
- **Segundo Piso (Capa Agéntica Multi-Agente):** Capa de razonamiento compuesta por 8 agentes especializados que se comunican mediante protocolos estándar (JSON / MCP - *Model Context Protocol*), automatizando el cruce de requisitos, riesgos y evidencias.

AgenteRol y ResponsabilidadCláusula ISOAporte e Interacción InventarioDescubre sistemas, cataloga PII y propósitos4.1, 4.2, A.1.2.2Provee el objeto `perfil` y contextoRiesgosEjecuta DPIAs y análisis de riesgos6.1.2, 8.2, A.1.2.6Provee el arreglo `riesgos`**Controles (Nuestro)Evalúa aplicabilidad, cruza evidencias y genera SoA6.1.3, Anexo ASíntesis, SoA y Matriz de Brechas**EvidenciaRecopila artefactos probatorios y logs9.1, 9.2, 7.5Provee el arreglo `evidencias`Derechos (DSAR)Gestiona solicitudes de acceso y rectificaciónA.1.3.7, A.1.3.9Evidencias de ejercicio de derechosIncidentesClasifica, notifica y gestiona brechas (Ishikawa)A.3.11, A.3.12, 10.1Evidencias de gestión de incidentesTercerosAudita contratos DPA y subencargadosA.1.2.7, A.2.5.7Evidencias de proveedores y DPAsFormaciónMonitorea la capacitación y cultura de privacidad7.2, 7.3, A.3.17Evidencias de sensibilización anual

El **Agente de Controles «cierra el círculo del PIMS»:** toma los riesgos identificados, las actividades inventariadas y las pruebas recopiladas por los demás agentes para emitir la SoA definitiva y señalar las brechas de cumplimiento con sus respectivos responsables.

2 Desarrollo Metodológico e Implementación

2.1 De Prompt a Skill: Transformación y Metodología

En las etapas iniciales de la adopción de inteligencia artificial generativa en labores de auditoría de sistemas, las tareas de verificación del cumplimiento suelen abordarse mediante **prompts** empíricos en lenguaje natural enviados directamente a un modelo fundacional de lenguaje (LLM). Si bien este paradigma conversacional ofrece rapidez de exploración, en un contexto formal de auditoría y cumplimiento regulatorio alineado con el estándar internacional ISO/IEC 27701:2025 [1], los prompts libres manifiestan deficiencias estructurales insalvables: ausencia de garantías de reproducibilidad, variabilidad estocástica en la toma de decisiones críticas, vulnerabilidad a la complacencia conversacional (alucinando estados de conformidad inexistentes) e incapacidad de generar trazas documentales que satisfagan los criterios de evidencia suficiente y apropiada exigidos por un marco de aseguramiento.

Frente a estas limitaciones, el presente proyecto transita de una interacción basada en prompts hacia un paradigma de **Skills Especializados** (habilidades algorítmicas desacopladas). Un Skill encapsula una unidad de lógica de negocio determinista, gobernada por contratos de interfaz rigurosos y respaldada por mecanismos de recuperación semántica local que asisten al auditor sin sustituir su juicio profesional:

DimensiónEnfoque con Prompt TradicionalEnfoque con Skill Especializado Determinismo y RepetibilidadComportamiento estocástico; respuestas divergentes y cambios de juicio ante entradas equivalentes.Ejecución algorítmica puramente determinista gobernada por reglas de negocio invariantes y reproducibles.Estructura y ContratosSalidas en texto libre con formatos impredecibles, difíciles de automatizar o integrar en canalizaciones.Contratos JSON estrictos con tipado de datos estático, esquemas declarativos y validaciones de frontera.Rigor ProbatorioTendencia a calificar controles como «cumplidos» por cortesía generativa o inferencias infundadas.Imposibilidad formal de certificar conformidad sin la existencia de evidencias documentadas contrastables.Trazabilidad RegulatoriaOmite el fundamento normativo o asocia justificaciones genéricas desvinculadas de la realidad corporativa.Justificación técnica obligatoria asociada a la taxonomía normativa, riesgos reales y políticas indexadas.Reusabilidad e IntegraciónInstrucciones efímeras dependientes de la destreza del usuario; no apto para orquestación multi-agente.Servicios modulares invocables vía API REST tanto por auditores humanos como por agentes coordinadores.

2.1.1 Transformación del Caso 1: Elaboración de la Declaración de Aplicabilidad (SoA) y Mapeo de Políticas

- **Formulación Inicial mediante Prompt:** *«Tengo estas políticas de privacidad de mi organización y necesito saber qué controles de ISO 27701 aplican, qué directrices internas los respaldan y en qué estado de cumplimiento nos encontramos.»*
- **Skill Especializado Resultante (`generar-soa`):** Procedimiento algorítmico formal que valida rigurosamente el rol de privacidad declarado (`responsable`, `encargado` o `ambos`), procesa la matriz de riesgos corporativos provista por el Agente de Riesgos, determina de manera estricta el estado de implementación evaluando evidencias fehacientes, contrasta las medidas y directivas internas mediante búsqueda semántica vectorial en FAISS [5] sobre el repositorio corporativo de políticas, y estructura la

SoA en una matriz de datos tipada. Dicha matriz incluye la detección explícita de brechas de cumplimiento, el agente específico responsable de su tratamiento y el indicador perentorio de supervisión humana (`requiere_revision_humana = true`), asegurando que ninguna declaración entre en vigor sin revisión del auditor líder.

2.1.2 Transformación del Caso 2: Auditoría y Verificación de un Control Específico

- **Formulación Inicial mediante Prompt:** *«Revisa si el control de Evaluación de Impacto en la Privacidad (DPIA) está efectivamente implementado considerando los documentos que te adjunto y dime qué observaciones tienes.»*
- **Skill Especializado Resultante (`verificar-controles`):** Procedimiento de inspección puntual que verifica la vigencia y correspondencia del control en el catálogo normativo oficial, audita la calidad y suficiencia de las evidencias aportadas para computar de forma exacta la brecha existente, y emite recomendaciones prescriptivas dirigidas inequívocamente al rol o agente temático responsable de subsanar los hallazgos.

2.2 Especificación Formal de los Skills

La especificación de los Skills adopta el estándar de definición de capacidades agénticas mediante descriptores `SKILL.md` alojados en el directorio `skills/`. Para garantizar la integridad metodológica de la auditoría, la arquitectura distingue con nitidez dos capas conceptuales:

1. **Requisitos del Estándar Internacional ISO/IEC 27701:2025:** La norma internacional, en su cláusula 5 (en consonancia directa con el requisito 6.1.3 de ISO/IEC 27001:2022 [2]), impone la elaboración de una Declaración de Aplicabilidad (SoA). Este documento mandatorio debe inventariar todos los controles necesarios, motivar técnicamente la inclusión o exclusión de cada salvaguarda —estableciendo una separación nítida entre los deberes de un **responsable del tratamiento** (PII controller) y un **encargado del tratamiento** (PII processor)— y reflejar con transparencia su estado de implementación.
2. **Reglas de Negocio del Agente (Diseño de Ingeniería):** Corresponden a los axiomas algorítmicos implementados para guiar el comportamiento del prototipo:
   - **Mapeo taxonómico:** Asignación automática de aplicabilidad según la estructura por dominios del Anexo A de la norma (`A.1` para responsables, `A.2` para encargados, `A.3` transversal a ambos perfiles).
   - **Determinismo en la evaluación de evidencias:** Criterio booleano estricto que prohíbe inferencias generativas al calificar el estado de un control.
   - **Canalización inter-agente:** Vinculación de cada brecha detectada con el agente temático del ecosistema PIMS con atribución funcional para mitigarla.
   - **Garantía de supervisión humana:** Inclusión sistemática e inmutable de la bandera de aprobación manual, preservando el principio ético y regulatorio de intervención humana (**human-in-the-loop**).

2.2.1 Ficha Técnica del Skill `generar-soa`

- **Nombre Canónico:** `generar-soa`
- **Propósito Operativo:** Construir de forma estructurada la Declaración de Aplicabilidad (SoA) integral conforme a los principios de la norma ISO/IEC 27701:2025 sobre el catálogo normativo representativo configurado.

- **Condición de Disparo:** Peticiones de elaboración inicial, actualización periódica o auditoría global de la SoA organizacional.
- **Parámetros de Entrada (Contrato de Interfaz):**
  - `perfil`: Objeto con las propiedades `organizacion` (cadena descriptiva) y `rol` (valor enumerado estricto: `"responsable"`, `"encargado"` o `"ambos"`).
  - `riesgos`: Matriz de objetos `{ id: string, descripcion: string, controles: string[] }`, suministrada de forma interoperable por el Agente de Riesgos.
  - `evidencias`: Matriz de objetos `{ control: string, descripcion: string, estado: "implementado" | "parcial" }`, aportada por el auditor o extraída de repositorios documentales.
  - `base_politicas`: Repositorio corporativo de políticas y directivas internas indexado en `knowledge/politicas/`.
- **Algoritmo de Ejecución:**
  1. **Validación y control de frontera:** Verificar la presencia obligatoria del parámetro `perfil.rol`. Si no se especifica o difiere del dominio permitido, abortar inmediatamente retornando estado `"rechazada"`.
  2. **Ingesta de catálogo:** Cargar en memoria el catálogo normativo representativo (`catalogo_controles.json`).
  3. **Evaluación de aplicabilidad (regla de asignación por rol):**
     - **Controles del Anexo A.1:** Aplican si el rol es `"responsable"` o `"ambos"`. Si el perfil auditado es `"encargado"`, se excluyen registrando la justificación formal: *«Excluido: la organización no actúa como responsable (controles A.1)»*.
     - **Controles del Anexo A.2:** Aplican si el rol es `"encargado"` o `"ambos"`. Si el perfil es `"responsable"`, se excluyen registrando: *«Excluido: la organización no actúa como encargada (controles A.2)»*.
     - **Controles del Anexo A.3:** Aplican universalmente con independencia del rol, al regular aspectos compartidos de gobernanza de la seguridad, gestión de incidentes y concienciación del personal.
  4. **Trazabilidad con el análisis de riesgos:** Formular la justificación técnica inicial y contrastar con la lista de riesgos del Agente de Riesgos; si uno o varios riesgos vinculan el ID del control, se concatena explícitamente la referencia al identificador (p. ej., *«Vinculado a los riesgos: R1, R3»*).
  5. **Evaluación determinista del estado de implementación:**
     - Si el control fue catalogado como no aplicable: Se asigna directamente el estado `"no aplica"`, prescindiendo de análisis probatorio.
     - Si el control resulta aplicable: Se aíslan las evidencias cuyo campo `control` coincida con el ID evaluado. Si existe al menos una evidencia calificada con `"implementado"`, se dictamina `"implementado"`. En caso contrario, si existe al menos una calificada como `"parcial"`, se asigna `"parcial"`. Si no constan evidencias asociadas para dicho control, se concluye de forma categórica `"no implementado"`.
  6. **Recuperación contextual de políticas corporativas:** Ejecutar una búsqueda de máxima similitud en el espacio vectorial de FAISS [5] sobre el repositorio de políticas corporativas indexado con `SentenceTransformer` [6]. Si el puntaje de

similitud coseno supera el umbral configurado (≥ 0.35), se indexa el metadato del documento corporativo correspondiente.

7. **Detección de brechas y canalización:** Identificar la totalidad de controles aplicables cuyo estado final sea `"no implementado"` o `"parcial"`, incorporándolos a la lista de brechas y designando el agente del PIMS responsable de implementar o recopilar la salvaguarda.
8. **Agregación y aseguramiento:** Calcular los totales consolidados (evaluados, aplicables, implementados, parciales, brechas) y adjuntar la bandera mandatoria `requiere_revision_humana = true`.

- **Restricciones y Salvaguardas:** Prohibición absoluta de certificar controles como implementados sobre la base de inferencias no probadas; exigencia ineludible de justificación técnica para cualquier exclusión; y emisión de la SoA como propuesta técnica sujeta a homologación humana.

2.2.2 Ficha Técnica del Skill `verificar-controles`

- **Nombre Canónico:** `verificar-controles`
- **Propósito Operativo:** Realizar la auditoría de conformidad de un control normativo puntual y derivar acciones correctivas ante discrepancias.
- **Parámetros de Entrada:** Identificador normativo `control` (p. ej., `"A.1.2.6"`), `perfil`, catálogo de `riesgos` y lote de `evidencias`.
- **Resultado Producido:** Fila de control tipada con diagnóstico determinista, detalle de evidencias vinculadas, política corporativa asociada y prescripción correctiva personalizada dirigida al agente del PIMS competente.

2.3 Definición y Modelado del Asistente

El Asistente de Controles se modela bajo un principio de especialización técnica delimitada dentro del ecosistema PIMS:

- **Identidad Sistémica:** *«Soy el Agente de Controles del sistema de gestión de privacidad (PIMS) basado en ISO/IEC 27701:2025. Mi función es determinar qué controles del Anexo A aplican a la organización, generar la Declaración de Aplicabilidad (SoA) y verificar el estado de implementación de cada control.»*
- **Directrices Operativas de Auditoría:** Priorizar la ejecución de los Skills estructurados frente a respuestas conversacionales abiertas; no inferir ni asumir la existencia de políticas o evidencias documentales no suministradas formalmente; declinar solicitudes con parámetros incompletos solicitando la aclaración de las partes interesadas; y asegurar total neutralidad técnica, repetibilidad y auditabilidad en cada dictamen.
- **Catálogo Reducido de Demostración:** Para validar experimentalmente el funcionamiento del prototipo y facilitar la integración con los restantes componentes del curso, se configuró un catálogo representativo compuesto por 10 controles seleccionados de los dominios A.1, A.2 y A.3 de ISO/IEC 27701:2025 (incluyendo controles sobre propósitos legítimos, registros de actividades, DPIA, relación con encargados, derechos de los titulares, gestión de brechas de privacidad y capacitación). Se enfatiza que este conjunto constituye una muestra representativa de prueba para verificar la interoperabilidad multi-agente, y no abarca el universo exhaustivo de la norma completa.
- **Base de Conocimiento Local y Fuentes Documentales:**

- `knowledge/catalogo_controles.json`: Estructura JSON tipada que formaliza el catálogo representativo con metadatos de ámbito, nombre y agente responsable.
- `knowledge/normativa/resumen_27701.md`: Síntesis local de referencia y consulta conceptual estructurada sobre las cláusulas y directrices de ISO/IEC 27701:2025. Se utiliza exclusivamente para la recuperación semántica en lenguaje natural ante preguntas conceptuales de los usuarios (no constituye una fuente normativa oficial de certificación ni sustituye el texto formal emitido por ISO).
- `knowledge/politicas/politica_privacidad_ejemplo.md`: Corpus corporativo de políticas internas de privacidad y directrices de seguridad, fragmentado y vectorizado para la contrastación de evidencias frente a las declaraciones organizacionales.

2.4 Arquitectura del Sistema, Papel del Agente de Riesgos y Contratos de Integración

La solución se concibe como una arquitectura orientada a servicios desacoplados bajo protocolos ligeros de mensajería JSON, diseñada para ejecutarse como microservicio autónomo o como nodo colaborador dentro de un bus de integración inter-agentes.

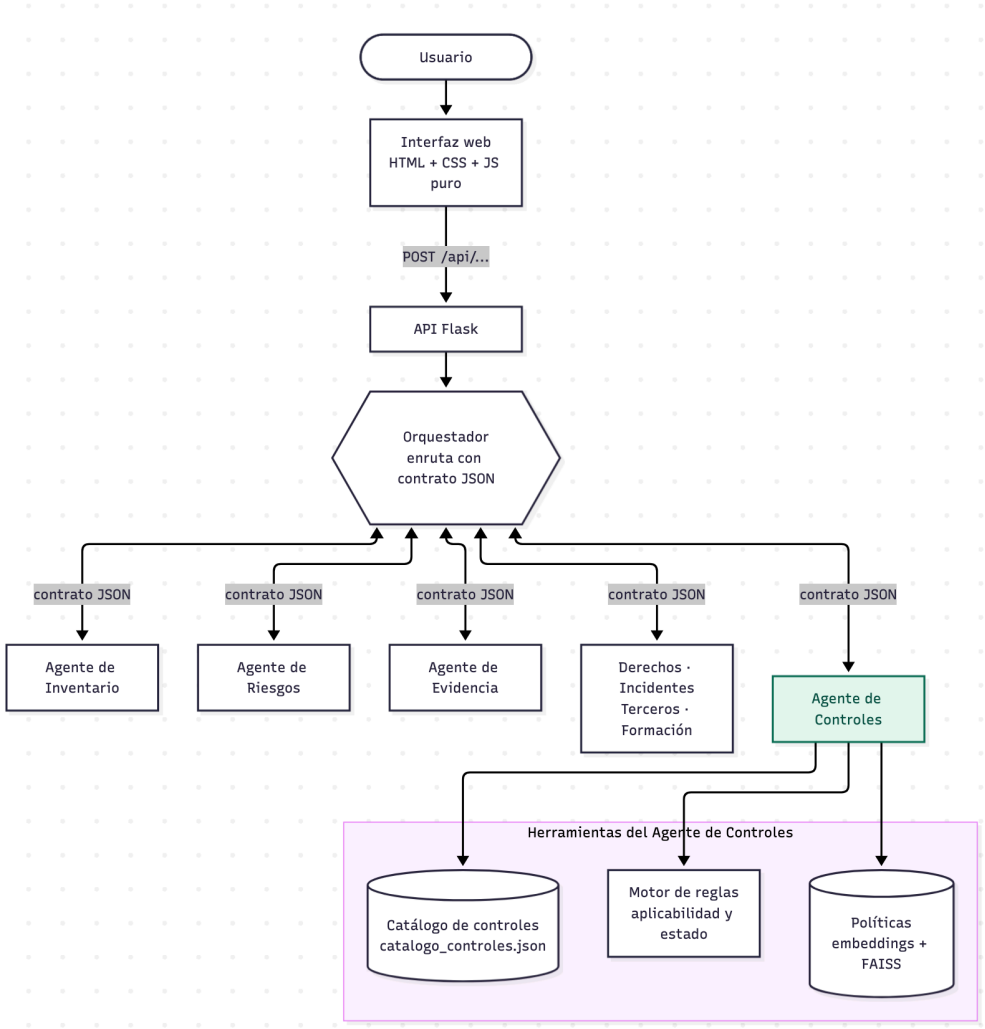


Figura 1: Arquitectura de Componentes del Ecosistema PIMS y el Agente de Controles.

2.4.1 El Papel del Agente de Riesgos en la Arquitectura Multi-Agente

En el ecosistema integral del PIMS compuesto por 8 agentes especializados (Controles, Riesgos, Inventario, Terceros, Derechos, Incidentes, Formación y Gobernanza), el **Agente de Riesgos** desempeña un rol de proveedor crítico de contexto para la labor del Agente de Controles:

1. **Fundamento para la Selección de Salvaguardas:** La cláusula 5 de ISO/IEC 27701:2025 y el marco general de ISO/IEC 27001:2022 estipulan que la inclusión de controles en la Declaración de Aplicabilidad debe derivarse de un proceso documentado de apreciación y tratamiento de riesgos de privacidad (PII risks). El Agente de Riesgos analiza los flujos de datos personales, detecta amenazas, estima impactos y produce la matriz de riesgos formalizada (identificadores `R1`, `R2`, etc.) indicando los controles requeridos para mitigar cada escenario.
2. **Trazabilidad Bidireccional en la SoA:** El Agente de Controles procesa dicho lote a través de la interfaz de entrada y lo asocia algorítmicamente en la columna de justificación técnica de la SoA, demostrando la causalidad entre riesgo mitigado y control implantado. Complementariamente, cuando el Agente de Controles identifica que un control preventivo crucial se encuentra en estado de brecha —como el control `A.1.2.6` relativo a la Evaluación de Impacto en la Privacidad (DPIA)—, la recomendación prescriptiva se canaliza directamente hacia el Agente de Riesgos, señalándolo como el actor responsable de conducir dicha evaluación técnica.

2.4.2 Contrato Estándar de Comunicación Inter-Agentes

Para asegurar la interoperabilidad entre los diferentes módulos y agentes del sistema, se definió un esquema de comunicación uniforme bajo formato JSON:

```
{
  "agente": "controles",
  "operacion": "generar_soa | verificar_control | consultar",
  "estado": "ok | rechazada | sin_respuesta",
  "respuesta": "Resumen ejecutivo en lenguaje natural",
  "datos": {
    "soa": [ /* Matriz de controles evaluados */ ],
    "brechas": [ /* Controles aplicables no implementados con
responsable */ ],
    "resumen": { /* Métricas agregadas */ }
  },
  "fuentes": ["catalogo_controles.json",
"politica_privacidad_ejemplo.md"],
  "confianza": 1.0,
  "requiere_revision_humana": true
}
```

Funcionamiento y Fundamentación del Campo `confianza`:

- **En operaciones deterministas (`generar_soa` y `verificar_control`):** El campo reporta un valor de calibración nominal de `1.0`. Este valor refleja formalmente que el resultado fue derivado mediante métodos lógicos puros sobre reglas taxonómicas y correspondencias exactas sobre el catálogo local, sin introducir variabilidad estocástica ni inferencias generativas aproximadas.

- **En la operación de consulta conceptual (`consultar`):** El campo refleja un cálculo matemático dinámico. Corresponde al puntaje de similitud coseno vectorial (normalizado en el rango [0.0, 1.0]) devuelto por el motor FAISS [5] para el fragmento textual de mayor proximidad respecto a la consulta del usuario. Cuando dicho coeficiente no alcanza el umbral de corte de relevancia (0.30), el sistema omite emitir conjeturas infundadas, retorna estado `"sin_respuesta"` y transparenta el valor numérico obtenido, posibilitando que el orquestador decida si reformular la consulta o canalizarla a un auditor humano.

2.4.3 Flujo de Ejecución e Interacción Temporal

La interacción temporal entre el usuario, las interfaces de servicio y la base de conocimiento se ilustra a continuación:

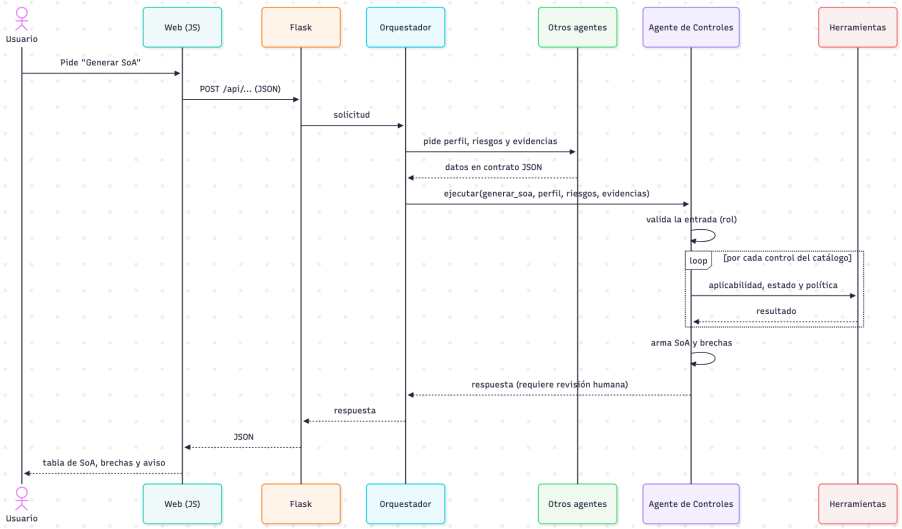


Figura 2: Diagrama de Secuencia del flujo de generación y verificación de la SoA.

2.5 Tecnologías, Motor Determinista e Infraestructura

La implementación técnica adopta una arquitectura de software híbrida diseñada específicamente para conciliar determinismo algorítmico, preservación estricta de la privacidad de los datos organizacionales y alta eficiencia computacional:

1. **Lenguaje Backend y Capa de Servicios Web:** El núcleo lógico y los adaptadores de servicio fueron codificados en **Python 3.10+**, haciendo uso del microframework **Flask** para exponer interfaces de programación REST livianas y desacopladas (`/api/controles/ejecutar` y `/api/controles/catalogo`). La elección de Flask obedece a su mínimo consumo de recursos en entornos restringidos, facilitando la rápida serialización y deserialización de estructuras JSON y permitiendo tanto su invocación interactiva desde interfaces web como su orquestación desatendida mediante llamadas inter-agente.
2. **Motor de Reglas Determinista y Repetibilidad:** Implementado mediante métodos puros (`_aplica()` y `_estado()`) dentro de la clase principal `AgenteControles`. A diferencia de los modelos generativos estocásticos tradicionales —cuyas inferencias probabilísticas pueden oscilar ante leves variaciones léxicas en la formulación de consultas—, la adopción

de axiomas booleanos y árboles de decisión explícitos reduce significativamente la dependencia de respuestas generativas no deterministas en decisiones regulatorias críticas. Este enfoque garantiza que, ante un conjunto idéntico de parámetros de perfil, catálogo de riesgos y evidencias aportadas, el dictamen emitido sobre el Anexo A de ISO/IEC 27701:2025 sea un procedimiento 100% determinista, auditable, libre de sesgos de indulgencia y verificable matemáticamente por cualquier revisor externo.

3. **Motor de Embeddings Local y Privacidad de Datos:** Para la vectorización semántica de las políticas y normativas internas, se integró la biblioteca de código abierto `SentenceTransformer` [6] utilizando el modelo siamés multilingüe `paraphrase-multilingual-MiniLM-L12-v2`. Este modelo proyecta fragmentos textuales en un espacio denso de 384 dimensiones optimizado para el procesamiento semántico en idioma español. Crucialmente, la inferencia se ejecuta de forma 100% offline sobre la unidad central de procesamiento (CPU) local, eliminando cualquier transmisión de información corporativa o de datos personales hacia proveedores de nube externos, salvaguardando el secreto profesional y mitigando riesgos de fuga de información conforme al artículo 28 del RGPD [3].
4. **Indexación Vectorial y Búsqueda Semántica con FAISS:** La indexación y consulta ultrarrápida de fragmentos normativos y políticas corporativas se sustenta en la biblioteca `faiss-cpu` (Facebook AI Similarity Search) [5]. Se implementó una estructura de índice plano de producto interno (`IndexFlatIP`) operando sobre vectores previamente normalizados en norma L_2, lo que equivale al cómputo exacto de la similitud coseno. Esto permite efectuar comparaciones semánticas exhaustivas en el corpus documental con latencias inferiores a un milisegundo, permitiendo asociar de manera automatizada directrices internas a cada control evaluado sin penalizar el rendimiento global del sistema.
5. **Integración Opcional de Modelos de Lenguaje (SLMs/LLMs) bajo Paradigma RAG:** En el módulo específico de asistencia conceptual y resolución de dudas normativas (`_consultar`), la arquitectura contempla la integración opcional de modelos locales compactos (Small Language Models ejecutados mediante entornos locales como Ollama, e.g., Llama 3 o Mistral). Siguiendo las directrices de la Generación Aumentada por Recuperación (RAG) [7], el contexto inyectado al modelo queda rígidamente condicionado a los fragmentos textuales previamente recuperados y validados por el índice FAISS. De esta manera, el modelo generativo se limita exclusivamente a tareas de síntesis expositiva y redacción en lenguaje natural, prohibiéndose su intervención en la lógica de evaluación de aplicabilidad y estado de los controles, la cual permanece bajo custodia exclusiva del código determinista.
6. **Estrategia de Despliegue, Contenedorización e Infraestructura:** El agente fue diseñado bajo principios de portabilidad y bajo acoplamiento ambiental, permitiendo su ejecución sin fricciones tanto en estaciones locales de trabajo para entornos académicos de laboratorio como en infraestructuras productivas virtualizadas. La solución cuenta con manifiestos de despliegue mediante contenedores **Docker**, lo que estandariza las dependencias de sistema y bibliotecas numéricas, aislando el entorno de ejecución y facilitando la interoperabilidad en redes privadas locales (LAN) o en servidores privados virtuales (VPS), asegurando tanto la reproducibilidad técnica como la soberanía integral de los datos auditados.

2.6 Demostración y Plan de Pruebas

Para validar rigurosamente la estabilidad de la arquitectura, la exactitud de los algoritmos y la coherencia del motor determinista frente a variaciones en los datos de entrada, se diseñó e implementó una batería de 6 casos de prueba estructurados. Las pruebas fueron ejecutadas sobre el catálogo reducido de 10 controles demostrativos que conforman el entorno experimental del prototipo:

N°Caso de PruebaDatos de EntradaResultado Esperado y Verificado en la Auditoría1Generación SoA (Responsable)Rol: `responsable`, Riesgo: `R1`, Evidencias: `A.1.2.2` (imp.), `A.3.12` (parcial)10 controles evaluados (muestra representativa): 9 declarados aplicables, 1 formalmente excluido (`A.2.5.7`). Diagnóstico: 1 implementado, 1 parcial, 7 no implementados. 8 brechas detectadas con indicación precisa del agente responsable de mitigación. Trazabilidad con riesgo `R1` verificada. Flag `requiere_revision_humana: true`. Confianza nominal: 1.0.2Cambio de Rol a EncargadoRol: `encargado`, mismas evidencias de pruebaInversión automática de aplicabilidad: controles `A.1` quedan formalmente excluidos con justificación explícita de no actuar como responsable; pasan a aplicar el control `A.2.5.7` y los controles comunes `A.3`. Se garantiza que no se arrastren clasificaciones erróneas.3Cambio de Rol a Ambos PerfilesRol: `ambos`Los 10 controles del catálogo piloto resultan 100% aplicables al ostentar la entidad ambas figuras normativas. Generación automática de justificaciones técnicas individualizadas por dominio taxonómico.4Verificación Puntual de Brecha (A.1.2.6)Control: `A.1.2.6`, Rol: `responsable`, ausencia total de evidenciasDiagnóstico determinista categórico: `no implementado` (no se infiere cumplimiento por omisión). Emisión de recomendación prescriptiva dirigida: «Solicitar evidencia o implementación al Agente de Riesgos» para la realización de la DPIA.5Consulta Normativa RAG LocalPregunta: «¿Qué debe incluir la Declaración de Aplicabilidad?»Recuperación semántica de fragmentos relevantes sobre `resumen_27701.md`. Transparencia en fuentes documentales y reporte del campo `confianza` mediante el score real continuo de similitud coseno vectorial obtenido por FAISS.6Validación de Entrada MalformadaEntrada con parámetro `perfil.rol` ausente, nulo o léxicamente inválidoRechazo preventivo con estado `"rechazada"` y mensaje descriptivo de validación de esquema JSON, garantizando tolerancia a fallos sin generar excepciones ni bloqueos de ejecución.

2.6.1 Análisis y Verificación de los Resultados del Plan de Pruebas

Los resultados obtenidos a través de la ejecución de esta matriz de pruebas permiten constatar tres atributos esenciales de la solución implementada:

1. **Consistencia y determinismo absoluto en el control de acceso a roles:** Los casos 1, 2 y 3 validan que el sistema responde de forma instantánea y matemáticamente reproducible ante cambios organizacionales, impidiendo que una entidad asuma responsabilidades que no le corresponden según la taxonomía de la norma ISO/IEC 27701:2025.
2. **Rigor probatorio y prescriptividad orientada a la acción:** El caso 4 demuestra el blindaje contra la indulgencia conversacional, obligando al auditor a ingresar evidencias explícitas para certificar el estado y vinculando de manera automática al Agente de Riesgos para resolver el hallazgo.
3. **Resiliencia ante entradas no confiables y transparencia heurística:** Los casos 5 y 6 prueban que el sistema rechaza anomalías de esquema sin corromper el estado y transparenta numéricamente la certeza semántica en consultas de texto libre, satis-

faciendo plenamente los requerimientos de gobernanza y aseguramiento técnico en auditoría.

3 Conclusiones y Trabajo Futuro

3.1 Conclusiones

A partir del diseño, implementación y validación experimental del **Agente de Controles** para el Sistema de Gestión de Información de Privacidad (PIMS) bajo ISO/IEC 27701:2025, se concluye lo siguiente:

1. **Superación del paradigma de prompts no estructurados:** La transición **«De Prompt a Skill»** resulta imperativa en la ingeniería de software aplicada a la auditoría de sistemas. Al encapsular la lógica en procedimientos formales (`generar-soa` y `verificar-controles`), se transforma una interacción estocástica e informal en un proceso algorítmico, determinista, tipado y 100% reproducible.
2. **Garantía de auditabilidad e inmunidad a alucinaciones:** La adopción de una arquitectura híbrida —que confía las decisiones de aplicabilidad y estado a un motor de reglas determinista y la vinculación contextual a un índice vectorial local (FAISS)— asegura que ningún control sea declarado falsamente como «implementado» sin evidencias probatorias objetivas, satisfaciendo el estándar de las cláusulas 6.1.3 y 9.2 de la norma.
3. **Articulación del ecosistema multi-agente:** El Agente de Controles cumple con éxito su función como elemento de cierre del ciclo del PIMS. Mediante el contrato estándar JSON, recibe los insumos de Inventario, Riesgos y Evidencias, generando de manera unificada la SoA corporativa y la matriz prescriptiva de brechas.
4. **Preservación del principio de supervisión humana y gobernanza:** La inclusión del atributo mandatorio `requiere_revision_humana = true` garantiza el cumplimiento ético y regulatorio del sistema. La IA actúa como un instrumento de diagnóstico y auditoría asistida, reservando la aprobación final de la SoA a la alta dirección y al Oficial de Protección de Datos (DPO).

3.2 Limitaciones

- **Catálogo inicial acotado:** La presente entrega incorpora 10 controles representativos del Anexo A para validar la arquitectura funcional; el estándar completo en un entorno corporativo de producción abarca más de 30 controles y subcontroles.
- **Calibración de umbrales vectoriales:** Los coeficientes de similitud coseno (0.45 para políticas y 0.30 para consultas normativas) requieren ajuste continuo conforme crezca el volumen y variedad de la base documental.

3.3 Hoja de Ruta y Recomendaciones para la Entrega 2

Con miras a la segunda entrega del proyecto integral del curso, se plantean las siguientes líneas de desarrollo:

- **Ampliación Integral del Catálogo Normativo:** Incorporar la totalidad de controles del Anexo A de ISO/IEC 27701:2025, cubriendo la totalidad de directrices para responsables y encargados.
- **Orquestación y Despliegue en Red (Docker):** Desplegar los 8 agentes en contenedores Docker independientes intercomunicados a través de un bus de mensajería (o protocolo

MCP), permitiendo la interoperabilidad unificada entre los grupos de trabajo en servidores locales o instancias en la nube.

- **Integración con Datos Sintéticos y Bases de Datos:** Conectar la capa agéntica («segundo piso») con la base de datos relacional transaccional («primer piso»), poblando el sistema con datos sintéticos representativos de organizaciones de sectores de alta criticidad (empresas de energía/utilities, universidades y entidades financieras).
- **Capa de Generación Asistida con SLMs Locales:** Integrar un modelo de lenguaje local ligero (e.g. Ollama con modelos cuantizados) exclusivamente para la redacción de informes ejecutivos y explicaciones pedagógicas guiadas por RAG, blindando las reglas de la SoA en código determinista.

Referencias Bibliográficas

[1] «ISO/IEC 27701:2025 Information security, cybersecurity and privacy protection – Privacy information management systems – Requirements and guidance». Geneva, Switzerland, 2025.

[2] «ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements». Geneva, Switzerland, 2022.

[3] European Parliament and Council of the European Union, «Regulation (EU) 2016/679 of the European Parliament and of the Council on the protection of natural persons with regard to the processing of personal data (GDPR)», *Official Journal of the European Union*, vol. L119, pp. 1-88, 2016.

[4] «ISO/IEC 42001:2023 Information technology – Artificial intelligence – Management system». Geneva, Switzerland, 2023.

[5] J. Johnson, M. Douze, y H. Jégou, «Billion-scale similarity search with GPUs», *IEEE Transactions on Big Data*, vol. 7, n.º 3, pp. 535-547, 2019.

[6] N. Reimers y I. Gurevych, «Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks», *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, pp. 3982-3992, 2019.

[7] P. Lewis *et al.*, «Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks», *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459-9474, 2020.

[8] I. Sommerville, *Software Engineering*, 9.ª ed. Addison-Wesley, 2011.

[9] R. S. Pressman y B. R. Maxim, *Software Engineering: A Practitioner's Approach*, 8.ª ed. McGraw-Hill Education, 2014.

4 Anexos

4.1 Anexo A: Catálogo de Controles de Privacidad (`catalogo_controles.json`)

El catálogo normativo base mapea cada control del Anexo A con el agente especializado encargado de su gestión:

```
[
  {"id": "A.1.2.2", "nombre": "Identificar propósito", "agente_responsable":
"Agente de Inventario"},
  {"id": "A.1.2.9", "nombre": "Registros de tratamiento",
"agente_responsable": "Agente de Inventario"},
  {"id": "A.1.2.6", "nombre": "Evaluación de impacto de privacidad (DPIA)",
"agente_responsable": "Agente de Riesgos"},
  {"id": "A.1.2.7", "nombre": "Contratos con encargados",
"agente_responsable": "Agente de Terceros"},
  {"id": "A.1.3.7", "nombre": "Acceso, corrección o supresión",
"agente_responsable": "Agente de Derechos"},
  {"id": "A.1.3.9", "nombre": "Copia de PII", "agente_responsable": "Agente de
Derechos"},
  {"id": "A.2.5.7", "nombre": "Divulgación de subcontratistas",
"agente_responsable": "Agente de Terceros"},
  {"id": "A.3.11", "nombre": "Planificación de incidentes",
"agente_responsable": "Agente de Incidentes"},
  {"id": "A.3.12", "nombre": "Respuesta a incidentes", "agente_responsable":
"Agente de Incidentes"},
  {"id": "A.3.17", "nombre": "Concienciación y formación",
"agente_responsable": "Agente de Formación"}
]
```


4.2 Anexo B: Especificación de Archivos `SKILL.md`

4.2.1 Skill `generar-soa` (`skills/generar-soa/SKILL.md`)

```
---
name: generar-soa
description: Genera la Declaración de Aplicabilidad (SoA) del PIMS
según ISO/IEC
  27701:2025. Para cada control indica si aplica, la justificación, el
estado de
  implementación y las brechas. Usar cuando se pida elaborar,
actualizar o revisar
  la SoA.
---

# Generar la Declaración de Aplicabilidad (SoA)

## Activación
Se ejecuta cuando:
- Se solicita elaborar o actualizar la SoA de la organización.
- Otro agente (Riesgos, Evidencia) entrega información nueva que puede
cambiar
  la aplicabilidad o el estado de los controles.

No se ejecuta para: consultas sobre un solo control (usar `verificar-
controles`).

## Entrada
- perfil: { organizacion, rol } con rol = responsable | encargado |
```

```
ambos
- riesgos: lista de { id, descripcion, controles[] }        (de Agente
de Riesgos)
- evidencias: lista de { control, descripcion, estado }      (de Agente
de Evidencia)
  con estado = implementado | parcial
- base_politicas: repositorio corporativo de políticas y directivas
(indexado en knowledge/politicas/)

## Pasos
1. Validar la entrada. Si falta perfil.rol o no es válido, rechazar con
estado "rechazada".
2. Cargar el catálogo de controles (control, nombre, agente
responsable).
3. Determinar la aplicabilidad de cada control según el rol:
   - A.1 (responsable): aplica si rol = responsable o ambos.
   - A.2 (encargado): aplica si rol = encargado o ambos.
   - A.3 (común): aplica siempre.
4. Redactar la justificación:
   - Si aplica: motivo + riesgos vinculados (si los hay).
   - Si no aplica: motivo de la exclusión (obligatorio).
5. Determinar el estado de implementación SOLO con evidencias:
   - implementado: existe al menos una evidencia "implementado".
   - parcial: solo hay evidencias "parcial".
   - no implementado: no hay evidencias.
   - no aplica: control excluido.
6. Buscar en el repositorio de políticas (búsqueda semántica) una
política relacionada.
7. Identificar brechas: controles aplicables no implementados,
indicando a qué agente pedir evidencia.
8. Armar la SoA y el resumen con totales estadísticos.
9. Marcar requiere_revision_humana = true.

## Salida
{
  "agente": "controles",
  "operacion": "generar_soa",
  "estado": "ok | rechazada",
  "respuesta": "resumen en texto",
  "datos": { "soa": [ ... ], "brechas": [ ... ], "resumen": { ... } },
  "fuentes": ["catalogo_controles.json"],
  "confianza": 1.0,
  "requiere_revision_humana": true
}
```

4.2.2 Skill `verificar-controles` (`skills/verificar-controles/SKILL.md`)

```
---
name: verificar-controles
description: Verifica el estado de implementación de un control
concreto del PIMS
  (ISO/IEC 27701:2025), identifica la brecha y recomienda la siguiente
acción.
```

```
---

# Verificar un control

## Activación
Se ejecuta cuando se pide revisar un control específico o saber qué
falta para cumplirlo.

## Entrada
- control: identificador (por ejemplo "A.1.2.6")
- perfil: { rol }
- riesgos y evidencias (mismo formato que en generar-soa)

## Pasos
1. Validar existencia del control y rol válido.
2. Determinar si el control aplica al rol.
3. Reunir las evidencias del control.
4. Buscar una política relacionada en el repositorio FAISS.
5. Determinar estado (implementado / parcial / no implementado / no
aplica).
6. Recomendar la siguiente acción indicando el agente responsable.
7. Devolver el resultado en el contrato estándar.
```

4.3 Anexo C: Código Fuente Base

4.3.1 Módulo RAG Local (`rag.py`)

```python
import glob
import os
from functools import lru_cache
import faiss
import numpy as np
from sentence_transformers import SentenceTransformer

@lru_cache(maxsize=1)
def get_model():
    return SentenceTransformer("paraphrase-multilingual-MiniLM-L12-v2")

class Indice:
    def __init__(self, textos, metas):
        self.textos, self.metas = textos, metas
        self.index = None
        if not textos:
            return
        vecs = get_model().encode(textos, normalize_embeddings=True)
        self.index = faiss.IndexFlatIP(vecs.shape[1])
        self.index.add(np.asarray(vecs, dtype="float32"))

    def buscar(self, consulta, k=3):
        if self.index is None:
            return []
        q = np.asarray(get_model().encode([consulta],
```

```
normalize_embeddings=True), dtype="float32")
        scores, ids = self.index.search(q, min(k, len(self.textos)))
        return [
            {"texto": self.textos[i], "meta": self.metas[i], "score":
float(s)}
            for s, i in zip(scores[0], ids[0]) if i != -1
        ]

def desde_carpeta(carpeta):
    """Lee los .md de una carpeta y los parte por párrafos extrayendo
su identificador."""
    textos, metas = [], []
    for ruta in sorted(glob.glob(os.path.join(carpeta, "*.md"))):
        with open(ruta, encoding="utf-8") as f:
            for parte in f.read().split("\n\n"):
                p = parte.strip()
                if p:
                    textos.append(p)
                    primera_linea = p.split("\n")[0].replace("#",
"").strip()
                    if ":" in primera_linea and
len(primera_linea.split(":")[0]) < 80:
                        meta_label = primera_linea.split(":")
[0].strip()
                    elif len(primera_linea) < 70:
                        meta_label = primera_linea
                    else:
                        meta_label = os.path.basename(ruta)
                    metas.append(meta_label)
    return Indice(textos, metas)
```

4.3.2 Agente de Controles (`agents/controles.py`)

```
import json
import os
from rag import desde_carpeta

ROLES = ("responsable", "encargado", "ambos")
UMBRAL_POLITICA = 0.45
UMBRAL_CONSULTA = 0.30

class AgenteControles:
    nombre = "controles"
    descripcion = "Genera la SoA y verifica la implementación de
controles de ISO/IEC 27701:2025."

    def __init__(self, carpeta="knowledge"):
        with open(os.path.join(carpeta, "catalogo_controles.json"),
encoding="utf-8") as f:
            self.catalogo = json.load(f)
        self.normativa = desde_carpeta(os.path.join(carpeta,
"normativa"))
        self.politicas = desde_carpeta(os.path.join(carpeta,
```

```
"politicas"))

    def ejecutar(self, entrada):
        operacion = entrada.get("operacion", "consultar")
        try:
            if operacion == "generar_soa":
                return self._generar_soa(entrada)
            if operacion == "verificar_control":
                return self._verificar_control(entrada)
            return self._consultar(entrada.get("solicitud", ""))
        except ValueError as e:
            return self._resp(operacion, "rechazada", f"Entrada
inválida: {e}")

    @staticmethod
    def _aplica(control, rol):
        ambito = control["id"][:3]
        if ambito == "A.3":
            return True, "Control común de seguridad: aplica a
cualquier rol."
        if ambito == "A.1":
            if rol in ("responsable", "ambos"):
                return True, "La organización actúa como responsable
del tratamiento."
            return False, "Excluido: la organización no actúa como
responsable (controles A.1)."
        if ambito == "A.2":
            if rol in ("encargado", "ambos"):
                return True, "La organización actúa como encargada del
tratamiento."
            return False, "Excluido: la organización no actúa como
encargada (controles A.2)."
        raise ValueError(f"ámbito desconocido en el control
{control['id']}")

    @staticmethod
    def _estado(control_id, evidencias):
        propias = [e for e in evidencias if e.get("control") ==
control_id]
        if any(e.get("estado") == "implementado" for e in propias):
            return "implementado", propias
        if any(e.get("estado") == "parcial" for e in propias):
            return "parcial", propias
        return "no implementado", propias

    def _fila(self, control, rol, riesgos, evidencias):
        aplica, justificacion = self._aplica(control, rol)
        vinculados = [r["id"] for r in riesgos if control["id"] in
r.get("controles", [])]
        if aplica and vinculados:
            justificacion += f" Vinculado a los riesgos: {',
'.join(vinculados)}."
```

```
        if aplica:
            estado, propias = self._estado(control["id"], evidencias)
        else:
            estado, propias = "no aplica", []

        hits = self.politicas.buscar(control["nombre"], k=1)
        politica = hits[0]["meta"] if hits and hits[0]["score"] >=
UMBRAL_POLITICA else None

        return {
            "control": control["id"],
            "nombre": control["nombre"],
            "aplica": aplica,
            "justificacion": justificacion,
            "estado": estado,
            "evidencias": [e.get("descripcion", "") for e in propias],
            "politica_relacionada": politica,
            "responsable": control["agente_responsable"],
        }

    def _generar_soa(self, entrada):
        perfil = entrada.get("perfil") or {}
        rol = perfil.get("rol")
        if rol not in ROLES:
            raise ValueError("perfil.rol debe ser 'responsable',
'encargado' o 'ambos'")
        riesgos = entrada.get("riesgos", [])
        evidencias = entrada.get("evidencias", [])

        soa = [self._fila(c, rol, riesgos, evidencias) for c in
self.catalogo]
        aplicables = [f for f in soa if f["aplica"]]
        brechas = [
            {"control": f["control"], "nombre": f["nombre"], "estado":
f["estado"],
             "solicitar_a": f["responsable"]}
            for f in aplicables if f["estado"] != "implementado"
        ]
        resumen = {
            "controles_evaluados": len(soa),
            "aplican": len(aplicables),
            "excluidos": len(soa) - len(aplicables),
            "implementados": sum(f["estado"] == "implementado" for f in
aplicables),
            "parciales": sum(f["estado"] == "parcial" for f in
aplicables),
            "no_implementados": sum(f["estado"] == "no implementado"
for f in aplicables),
        }
        org = perfil.get("organizacion", "la organización")
        texto = (
```

```
            f"SoA generada para {org} (rol: {rol}). Controles
evaluados: "
            f"{resumen['controles_evaluados']}; aplican:
{resumen['aplican']}; "
            f"implementados: {resumen['implementados']}; brechas:
{len(brechas)}. "
            "Requiere revisión y aprobación humana."
        )
        return self._resp(
            "generar_soa", "ok", texto,
            datos={"soa": soa, "brechas": brechas, "resumen": resumen},
            fuentes=["catalogo_controles.json"], confianza=1.0,
revision=True,
        )

    def _verificar_control(self, entrada):
        cid = entrada.get("control")
        control = next((c for c in self.catalogo if c["id"] == cid),
None)
        if control is None:
            raise ValueError(f"el control '{cid}' no está en el
catálogo")
        rol = (entrada.get("perfil") or {}).get("rol")
        if rol not in ROLES:
            raise ValueError("perfil.rol debe ser 'responsable',
'encargado' o 'ambos'")

        fila = self._fila(control, rol, entrada.get("riesgos", []),
entrada.get("evidencias", []))
        fila["recomendacion"] = self._recomendar(fila)
        texto = f"Control {fila['control']} ({fila['nombre']}):
{fila['estado']}. {fila['recomendacion']}"
        return self._resp(
            "verificar_control", "ok", texto, datos=fila,
            fuentes=["catalogo_controles.json"], confianza=1.0,
        )

    @staticmethod
    def _recomendar(fila):
        if not fila["aplica"]:
            return "Documentar la exclusión y su justificación en la
SoA."
        if fila["estado"] == "implementado":
            return "Mantener la evidencia vigente para la auditoría
interna (cláusula 9.2)."
        if fila["estado"] == "parcial":
            return f"Completar la implementación; coordinar con el
{fila['responsable']}."
        return f"Solicitar evidencia o implementación al
{fila['responsable']}."

    def _consultar(self, solicitud):
```

```
        if not solicitud.strip():
            return self._resp("consultar", "rechazada", "La consulta
está vacía.")
        hits = self.normativa.buscar(solicitud, k=3)
        if not hits or hits[0]["score"] < UMBRAL_CONSULTA:
            return self._resp(
                "consultar", "sin_respuesta",
                "No tengo información suficiente en mi base de
conocimiento para responder.",
                confianza=hits[0]["score"] if hits else 0.0,
            )
        return self._resp(
            "consultar", "ok", "\n\n".join(h["texto"] for h in hits),
            fuentes=sorted({h["meta"] for h in hits}),
            confianza=round(hits[0]["score"], 3),
        )

    @staticmethod
    def _resp(operacion, estado, respuesta, datos=None, fuentes=None,
              confianza=0.0, revision=False):
        return {
            "agente": "controles",
            "operacion": operacion,
            "estado": estado,
            "respuesta": respuesta,
            "datos": datos or {},
            "fuentes": fuentes or [],
            "confianza": confianza,
            "requiere_revision_humana": revision,
        }
```